Security audit — Nhill 0.1.0 → 2.0.0

> **Date:** 26 October 2026 · **Nature:** code and configuration review (“white box”), dependency check against public vulnerability databases. **This is not a penetration test**: no Nhill server could be run in the audit environment (dependencies could not be installed). No claim of absence of vulnerabilities is made. Items marked “verified” were verified by reading the source code and, where stated, by running tests.

1. Summary

Nhill’s security model is **serious**: the server decides everything (roles, limits, subscription), establishments are isolated by forced PostgreSQL *row-level security*, passwords are hashed with Argon2id, tokens are opaque, short-lived and rotating, payment provider secrets are encrypted, no secret is present in the repository, backups are encrypted with `age`.

The main risks identified are:

#	Risk	Severity	Status
S1	**cpp-httplib 0.14**: CVE-2025-46728 and CVE-2025-53629 (memory exhaustion with chunked requests, CVSS 7.5)	**High**	Mitigated by Caddy (`request_body max_size 6MB`); **upgrade to ≥ 0.23.0 to do**
S2	**Frozen embedded Qt 6.4.2 runtime** in the 0.1.0 Debian 13 packages (e.g. CVE-2024-39936, HTTP/2, fixed in Qt 6.5.7 / 6.7.3 and in Debian 13’s qt6-base)	**High**	2.0.0: **native** Debian 13 packages (system Qt, updated by Debian) through the CI; embedded variant discouraged
S3	**No account recovery**: an owner who forgets the password loses access; risk of dangerous workarounds (shared accounts)	High (operations)	Open — needs e-mail delivery
S4	**Minimum length lowered to 8 characters** (requirement) whereas NIST SP 800-63B-4 recommends 15 characters for a password used alone	Medium (accepted risk)	Compensations: wider blocklist, rate limiting, Argon2id, other sessions closed on change; **decision to be recorded by the owner**
S5	`X-Forwarded-For` read from the left: forgeable behind a proxy that *appends* the header (bypass of per-IP limits)	Low (the provided Caddyfile replaces the header)	**Fixed in 2.0.0** (right-most entry)
S6	DRC personal-data compliance not established (declaration to the authority, transfer outside the DRC if hosted on Supabase abroad, data protection officer)	High (legal)	See the legal file; actions for the operator
S7	No continuous WAL archiving: up to 24 h of data loss possible	Medium	Open — recommendation
S8	No monitoring or alerting (failed backup, certificate, disk)	Medium	Open — recommendation
S9	`ILIKE` search with unescaped `%` and `_` (user-supplied patterns)	Low	Open — no injection (bound parameters), only wider patterns

2. Scope and threat model

- **Assets:** establishments' business data (customers, invoices, stock, payments), accounts and sessions, platform secrets (`NH_SECRET_KEY`, webhook secrets, database credentials), backups, audit log.
- **Adversaries considered:** anonymous Internet user; authenticated user of another establishment; employee with limited rights (cashier); former employee; person who obtained an establishment code; console administrator with limited rights; network attacker on a public Wi-Fi.
- **Out of scope:** compromise of the user's device or of the hosting provider, physical attacks, volumetric denial of service.

3. Verified controls

Area	Control	Evidence
Authentication	Argon2id (libsodium), configurable parameters (`NH_ARGON2_OPS=3`, `NH_ARGON2_MEM_KIB=65536`), rehash on login when parameters increase	`server/src/util/crypto.cpp`, `services/auth.cpp` l. 90-106
	Constant-time comparison; dummy hash for an unknown e-mail (no timing enumeration)	`auth.cpp` l. 20, 95-101
	Password rule shared by client and server: **≥ 8 characters** (Unicode code points), ≤ 128 bytes, refusal of common (40 entries), repetitive or e-mail-equal passwords; no composition rule, no periodic expiry	`common/src/validation.cpp`; `Validation.*` tests **run: 20/20**
	Password change: checks the old one, closes the other sessions, audited	`auth.cpp` l. 268-287; test `Auth.LogoutAndPasswordChangeRevokeSessions`
	Rate limiting stored in the database (8/15 min per e-mail, 40 per IP, etc.)	`services/common.cpp` (`throttle`); test `Auth.BruteForceIsThrottled`
Sessions	Opaque 32-byte tokens, only the SHA-256 is stored; access 15 min; refresh 30 days, rotation, reuse → family revocation	`auth.cpp`, test `Auth.LoginRefreshRotationAndReuseDetection`
	Client: refresh token in the keychain (QtKeychain), never in clear text; console: token in memory	`client/src/core/session.cpp`
2FA	**Not imposed** on establishment users (requirement); **mandatory (TOTP RFC 6238, non-replayable code) for the platform console**	`services/admin.cpp` l. 49-130
Authorisation	Roles × permissions checked server-side on every route; suspended subscription → read-only; suspended/closed establishment	`http/app.cpp` (`roleHas`, `wrap`)
Isolation	**Forced** RLS on 30 business tables, establishment context per transaction, `NOBYPASSRLS` application role owning no object; RLS violation → 404 without detail; cross-establishment isolation tests	`db/migrations/0003_security.sql`, `app.cpp` (`42501` → 404), `Isolation.*` tests

Area	Control	Evidence
SQL injection	All values are bound parameters (`$1…`); dynamic fragments are code constants; object names through `quote_name`	review of `services/*.cpp`, `setup.cpp`
Input validation	JSON object required, lengths, e-mails, phones, UUIDs, dates, fixed-precision amounts, enumerations	`services/common.*`, `common/validation`
Transport	Client: HTTPS required except for a local address (`insecure_url`); server behind Caddy (automatic TLS, HSTS, `nosniff`, `DENY`, `no-referrer`); server listening on 127.0.0.1	`client/src/core/apiclient.cpp` l. 50-92, `deploy/caddy/Caddyfile`
API headers	`X-Content-Type-Options`, `X-Frame-Options`, `Referrer-Policy`, `Cache-Control: no-store`; body ≤ 8 MiB, read/write timeouts	`app.cpp` (constructor)
Secrets	No secret in the repository (pattern search: Stripe, AWS, JWT keys, private keys, literal passwords — 0 hits outside examples); `server.env` refused if readable by others; provider secrets write-only and encrypted (secretbox)	automated search; `config.cpp`
Logs	No password or token in logs; e-mails masked; application error reports filtered (“password” strings rejected, personal data masked)	`jobs.cpp` l. 163, `appcontext.cpp` l. 257, `Support.*` tests
Webhooks	Provider HMAC/signature, timestamp and amount verified; idempotent processing	`subscriptions.cpp` l. 601-630, `Webhook.*` tests
Backups	`pg_dump	age (the clear dump never touches the disk), dedicated nhill_backup` role, rotation	
Installation	One-time setup token (60 min) printed in the local log; generated role passwords (192 bits); configuration file written atomically with mode 0600	`setup.cpp`, `Setup.*` tests

4. Dependency vulnerabilities

Dependency (delivered version)	Vulnerability	Effect	Fix	Nhill situation
cpp-httplib 0.14	**CVE-2025-46728** (NVD, CVSS 3.1: 7.5) — size limits not enforced for chunked bodies or bodies without `Content-Length`	Memory exhaustion, server crash	0.20.1	Ubuntu 24.04 package / embedded copy in Debian 13 at 0.14

Dependency (delivered version)	Vulnerability	Effect	Fix	Nhill situation
cpp-httplib 0.14	**CVE-2025-53629** (NVD, CVSS 7.5) — unbounded memory allocation with `Transfer-Encoding: chunked`	Same	0.23.0	Same. **Mitigation in place**: Caddy rejects bodies > 6 MB before the server (workaround recommended by the advisory). **Action**: vendor cpp-httplib ≥ 0.23 (single header)
Qt 6.4.2 (embedded runtime of the 0.1.0 Debian 13 packages)	**CVE-2024-39936** (HTTP/2: security decisions before `encrypted()`), and later Qt advisories	Depends on the advisory	Qt 6.5.7 / 6.7.3; Debian 13 `qt6-base 6.8.2+dfsg-9+deb13u2` fixed	2.0.0: build the Debian 13 packages against the system Qt
libharu 2.3.0, libsodium 1.0.18, libpqxx 7.8	No blocking advisory identified during the audit	—	—	Updated by the distribution when dynamically linked

5. Password and 2FA policy (2.0.0 decision)

Owner requirement: minimum 8 characters, no arbitrary periodic change, no systematic 2FA.

Implementation:

1. Minimum **8 characters** (code points, not bytes) at account creation (new establishment), when joining by invitation, at password change and at the first console access. There is no reset flow: the rule will apply to it as soon as it exists (same shared `checkPassword` function).
2. Validation **in the interface** (instant, same C++ code) **and on the server** (authoritative).
3. Kept: Argon2id, refusal of common/repetitive/e-mail-equal passwords, rate limiting, session revocation on change.
4. **2FA:** not imposed on establishment users; **kept mandatory for the platform console**, whose accounts can suspend establishments and manage subscriptions and payment providers: removing it would remove an indispensable protection. With 2FA, 8 characters meet the NIST SP 800-63B-4 § 3.1.1.2 minimum for a password used in multi-factor authentication.
5. **Residual risk (S4):** for a password used alone, NIST SP 800-63B-4 requires at least 15 characters. Recommendations: offer optional 2FA to owners (evolution), check passwords against a list of breached passwords (k-anonymity), and keep rate limiting.

6. Personal data and multi-establishment

- **Separation of customer data:** ensured by forced RLS + server queries; tested.
- **Platform statistics:** aggregates without named data, consultation visible to the establishment (to be mentioned in the privacy policy).
- **Employee activity log:** processing of employees' personal data — staff must be informed.
- **DRC framework:** Ordonnance-loi n° 23/010 of 13 March 2023 (Digital Code, Book III, personal data); the data protection authority is provisionally exercised by the ARPTC; decision n° 039/ARPTC/CLG/2025 of 11 September 2025 (declaration, authorisation, transfers, fees). If the database is hosted outside the DRC (e.g. Supabase), the **transfer** requires prior authorisation (Art. 187 and 201-202 according to the available commentaries). Details, sources and reservations: `legal/en/00-legal-research.md`.

7. Residual risks and actions

Priority	Action	Owner
1	Vendor cpp-httplib ≥ 0.23.0 and rerun the server tests; keep Caddy's body limit	Development
2	Native Debian 13 packages (CI `linux-packages.yml`); remove the embedded-runtime variant	Development
3	E-mail transport (SMTP with TLS) then password reset through a single-use link (15 min, hashed in the database), optional 2FA for owners	Development
4	Personal-data declarations and, if hosted outside the DRC, transfer authorisation; appointment of a data protection officer; record of processing	Operator + lawyer
5	Continuous WAL archiving or a Supabase plan with PITR; quarterly restore test	Operations
6	Monitoring: `/health`, failed backups, TLS expiry, disk space, 5xx errors	Operations
7	External penetration test before the broad commercial opening	Operator
8	Escape `%` / `_` in `ILIKE` searches	Development

8. Sources

- NVD — CVE-2025-46728: https://nvd.nist.gov/vuln/detail/CVE-2025-46728 (Tenable summary: https://www.tenable.com/cve/CVE-2025-46728)
- NVD — CVE-2025-53629: https://nvd.nist.gov/vuln/detail/CVE-2025-53629
- Debian Security Tracker — CVE-2024-39936: https://security-tracker.debian.org/tracker/CVE-2024-39936
- NIST SP 800-63B-4, § 3.1.1.2 (passwords): https://pages.nist.gov/800-63-4/sp800-63b.html
- DRC Digital Code, text published by Droit-Numérique.cd: https://droitnumerique.cd/code-du-numerique-congolais-rdc-pdf/
- Avocats.cd — business compliance (ARPTC decision 039/2025): https://avocats.cd/blog/donnees-personnelles-en-rdc-comment-les-entreprises-doivent-se-conformer
- Droit-Numérique.cd — transfers outside the DRC: https://droitnumerique.cd/le-transfert-des-donnees-personnelles-hors-de-la-rd-congo/